

Preparatory Material for the Treatment Group

Security Objectives:

Project documentation often contains security-relevant statements that are indicative of the security requirements of a system. To identify security-relevant statements in project documentation, it can be helpful to think in terms of security objectives of the software system. The following table provides a guide for understanding security objectives and a guide to identifying statements that indicate the need for each security objective.

Confidentiality (C)	The degree to which the "data is disclosed only as intended" Statements that indicate a need for confidentiality: • presence of read-type verbs (read, view, display, share, alert, use, export, retrieve, report etc) when accessing a sensitive resource • securing or restricting access to a sensitive resource • specification of user roles and access rules (e.g., granting or revoking access)
Integrity (I)	"The degree to which a system or component prevents unauthorized access to, or modification of, computer programs or data." Statements that indicate a need for integrity: • presence of write-type verbs (create, update, delete, save, auto-populate, review, verify, generate, define, apply etc) when accessing a sensitive resource • accuracy, consistent understanding and interpretation of sensitive information • auto-population or merging of sensitive information • environmental checks (firewall, denial of service, virus checking, app firewalls)
Identification & Authentication (IA)	The need to establish and verify the identity of a user, process or device. Statements that indicate a need for identification & authentication: • need to identify / verify the entity (user or system) accessing a sensitive resource • need to identify / verify the source of data (e.g., patient originated data vs. clinic originated data)
Availability (A)	"The degree to which a system or component is operational and accessible when required for use." Statements that indicate a need for availability: • time or location constraints on information (e.g., real-time information) • data retention, historical or longitudinal data (available over a period of time) • checks and limits on resource utilization • backups, replication or archiving of resources
Accountability	Degree to which actions affecting software assets "can be traced to the actor responsible for the action" Statements that indicate a need for accountability: • recording of actions (e.g., accessing a resource) related to sensitive resources • recording of events (e.g., alerts and notifications) related to sensitive resources • ability to reconstruct history of actions and events • preventing someone or a component from denying they performed an action • transactions of data (create, read, update, delete, merge, unmerge, assign, ...)
Privacy (PR)	The degree to which an actor can understand and control how their information is used. Statements that indicate a need for privacy: • ability of an individual to exercise control over the collection, use and dissemination of his or her personally identifiable information (e.g., by providing consent) • gathering, usage, disclosure, and management of user or client data • masking of the identity of specific users or individuals • legal and compliance issues related to personally identifiable information

Security Functional Requirements:

For each security objective, we now present a set of context-specific templates and example security functional requirements that can be generated using these templates.

	ID	Description	Example
Confidentiality	C1	Maintaining the confidentiality of data <i>Given:</i> <subject> = user <resource> = sensitive information <action> = create/read/update/delete type actions <i>Add Security Requirements:</i> • The system shall enforce access privileges that <enable prevent> <subject> to <action> <resource>. [see AY1, I1, I2, I4] • The system shall encrypt <resource> and store <resource> in encrypted format using an industry-approved encryption algorithm. [see AY3, I2, I4] • The system shall transmit <resource> data in encrypted format to and from the authorized <subject>. [see I4] • The system shall monitor the status and location of system components that may contain unencrypted <resource> data.	Statement: The system shall provide a means to edit discharge instructions for a particular patient. Security Requirements: • The system shall enforce access privileges that enable authorized users to edit discharge instructions for a particular patient. • The system shall encrypt discharge instructions and store discharge instructions in encrypted format using an industry-approved encryption algorithm. • The system shall transmit discharge instructions in encrypted format to and from authorized users. • The system shall monitor the status and location of system components that may contain unencrypted discharge instructions data.
	I1	Maintaining integrity during read-type actions <i>Given:</i> <subject> = system, user or role <resource> = sensitive information <action> = read / view / display / send / receive <i>Add Security Requirements:</i> • The system shall ensure consistent understanding of <resource> by the <subject> during <action>. [see AY1] • The system shall have provision to report errors in <resource> during <action>. [see AY1]	Statement: All users should be able to see and view deleted and active documents. Security Requirements: • The system shall ensure consistent understanding of deleted and active documents by the user during viewing. • The system shall have provision to report errors in deleted and active documents during viewing.
	I2	Maintaining integrity during write-type actions <i>Given:</i> <subject> = system, user or role <resource> = sensitive information <action> = create / update / auto-populate / merge <i>Add Security Requirements:</i> • The system shall ensure that all mandatory information is provided for the <resource> before <action>. • The system shall protect against loss of information during <action>. • The system shall have provision to report errors in <resource> during <action>. [see AY1] • The system shall have provision to report errors in <resource> after <action>. [see AY1] • The system shall have provision to correct errors in <resource> if errors are detected. [see AY1] • The system shall ensure synchronization of <resource> if multiple <subject>s can perform	Statement: There must therefore be some capacity within the EHRI to merge multiple instances of patient records into a single record. Security Requirements: • The system shall ensure that all mandatory information is provided for the patient records before merging. • The system shall protect against loss of information during merging patient records. • The system shall have provision to report errors in patient records during merging. • The system shall have provision to report errors in patient records after merging. • The system shall have provision to correct errors in patient records if errors are detected. • The system shall ensure synchronization of patient records if multiple users can perform merging on patient records simultaneously.

	ID	Description	Example
		<action> on <resource> simultaneously. [see AY1]	
	I3	Maintaining integrity during delete actions <i>Given:</i> <subject> = system, user or role <resource> = sensitive information <action> = delete <i>Add Security Requirements:</i> The system shall ensure that <action> on <resource> is performed in accordance with the retention policy. [see AY1]	Statement: Add functionality to be able to delete unpublished versions of an intake. Security Requirements: The system shall ensure that deleting unpublished versions of an intake is performed in accordance with the retention policy.
	I4	Maintaining integrity of unchangeable objects <i>Given:</i> <resource> = write-once information (e.g., log files) <i>Add Security Requirements:</i> The system shall not allow modification of <resource> by any user. [see AY1]	Statement: The system shall prevent modifications to the audit records. Security Requirements: The system shall not allow modification of audit records by any user.
Availability	A1	Maintaining availability of data <i>Given:</i> <time> = length of time, typically one year <keywords> = retention archive history <resource> = information <action> = read / view / display / send / receive / access <i>Add Security Requirements:</i> - The system shall store and make available <object> for a period of at least <time period>. [see C1] - The system shall provide the capability for an administrator to purge data that is at least <time period> old and in accordance with organizational retention policy. [see I4]	Statement: VLER DAS stores event descriptions in an audit log for a minimum of six (6) years. Security Requirement: - The system shall store and make available audit event descriptions for a period of at least 6 years. - The system shall provide the capability for an administrator to purge data that is at least 6 years old and in accordance with organizational retention policy. [see I4]
	A2	Maintaining appropriate response time <i>Given:</i> <time> = short duration, typically less than 10 seconds <action> = any action present <i>Add Security Requirements:</i> - The system shall respond to user <action> within <time period>. - The system shall provide monitoring capabilities to ensure that response time falls within <time period>.	Statement: respond to requests for access to a patient or person's PHI within a reasonable time. Security Requirement: - The system shall respond to user access to a patient within a reasonable time. - The system shall provide monitoring capabilities to ensure that response time falls within reasonable time period.
	A3	Maintaining service availability <i>Given:</i> <time duration> = time of day for service/system to be available <service> = any system component present <action> = optional action <i>Add Security Requirements:</i> - The system shall ensure <service> to user <action> during <time period>. - The system shall provide monitoring capabilities to ensure that <service> is available to users / other	Statement: If the system claims to be available 24 by 7 then the system shall have ability to run a backup concurrently with the operation of the application. Security Requirement: - The system shall ensure system availability to the user 24 by 7. - The system shall provide monitoring capabilities to ensure that system is available to users 24 by 7.

	ID	Description	Example
		system components during <time period>	
	A4	Provide backup and recovery capabilities <i>Given:</i> <keyword> = backup, recovery <i>Add Security Requirements:</i> The system shall have the capability to produce backups and recover the system from the backups. The backup and recovery selections must take into account system recovery time objectives as well as system data recovery point objectives. [See C1]	Statement: If the system claims to be available 24 by 7 then the system shall have ability to run a backup concurrently with the operation of the application. Security Requirement: The system shall have the capability to produce backups and recover the system from the backups. The backup and recovery selections must take into account system recovery time objectives as well as system data recovery point objectives.
	A5	Limit resources to ensure capacity and performance constraints <i>Given:</i> <resource> = any resource <limiter> = limit on the number of records or size of the record <i>Add Security Requirements:</i> - The system shall limit the number of records presented to the user for <resource> when the request limit of <limiter> is reached. - The system shall notify the user that the maximum number of records was returned.	Statement: VLER DAS receives a maximum of 500 results in reverse chronological order by Creation Date. Security Requirements: - The system shall limit the number of records presented to the user for VLER DAS results when the request limit of 500 results is reached. - The system shall notify the user that the maximum number of records was returned.
Integrity: Identification & Authentication	IA1	Need to select context for roles or other attributes affecting accessibility to data. <i>Given:</i> Statement to choose a specific role or attribute for system access. <i>Add Security Requirement:</i> The system shall ensure the user has select <context> prior to perform any further action within the system. [see AY3]	Statement: Include a prompt for staff when they log into OSCAR that asks them to choose their current clinic location before they proceed to the appointment schedule for that day. Security Requirement: The system shall not ensure the user selects their current clinic location before any further action is taken within the system.
	IA2	Unique accounts should exist for each user. <i>Given:</i> Statement implying users need to be uniquely identified <i>Add Security Requirement:</i> A series of security requirements needs to be developed to maintain user lists or delegating that responsibility to some other component within the targeted environment. Requirements need to be created to authenticate the specified users based upon selected authentication factors (password, bio-metrics, tokens, certificates, etc.)	Statement: All users are registered and uniquely identified. Security Requirement:
Accountability	AY1	Logging transactions with sensitive data <i>Given:</i> <subject> = user or role <resource> = sensitive information	Statement: The system should provide the ability to check medications against a list of drugs noted to be ineffective for the patient in the past.

	ID	Description	Example
		<action> = create/read/update/delete <i>Add Security Requirements:</i> • The system shall log every time <subject> performs the <action> on <resource>. • At a minimum, the system shall capture the following information for the log entry: <subject> identification, timestamp, <action>, <resource>, and identification of the owner of <resource>. • The system shall prevent all users from modifying the log entry. [see I4] • The system shall allow only authorized auditors to view the log entry. [see I1, AY1]	Security Requirements: • The system shall log every time the user checks medications against a list of drugs noted to be ineffective for the patient in the past. • At a minimum, the system shall capture the following information for the log entry: user identification, timestamp, check, medication, <patient identification>. • The system shall prevent all users from modifying the log entry. • The system shall allow only the authorized auditors to view the log entry.
	AY2	Logging authentication events <i>Given:</i> <subject> = user or role <action> = logging-in, logging-out <i>Add Security Requirements:</i> • The system shall log every time <subject> logs into and logs out of the system. • At a minimum, the system shall capture the following information for the log entry: <subject> identification, timestamp, <action>. • The system shall prevent all users from modifying the log entry. [See I4] • The system shall allow only authorized auditors to view the log entry. [see I1, AY1]	Statement: The EHRi and all POS systems connected to the EHRi must robustly authenticate users. Security Requirements: • The system shall log every time the user logs into and logs out of the system. • At a minimum, the system shall capture the following information for the log entry: user identification, timestamp, login/logout. • The system shall prevent all users from modifying the log entry. • The system shall allow only authorized auditors to view the log entry.
	AY3	Logging system events <i>Given:</i> <action> = system-level action that cannot be traced to a specific user account <i>Add Security Requirements:</i> • The system shall log every time <action> happens. • At a minimum, the system shall capture the following information for the log entry: timestamp, <action> • The system shall prevent all users from modifying the log entry. [see I4] • The system shall allow only authorized auditors to view the log entry. [see I1, AY1]	Statement: The system shall be able to generate a backup copy of the application data, security credentials, and log or audit files. Security Requirements: • The system shall log every time backup happens. • At a minimum, the system shall capture the following information for the log entry: timestamp, backup • The system shall prevent all users from modifying the log entry. • The system shall allow only authorized auditors to view the log entry.
Privacy	PR1	Usage of personal information <i>Given:</i> <subject> = user or role <resource> = sensitive information <action> = create/read/update/delete/disclose <i>Add Security Requirements:</i> • The system shall allow the owner of <resource> to	Statement: Nurses require access to historical patient data to support patient interaction and care planning. Security Requirements: • The system shall allow the owner of historical patient data to be notified of potential authorized uses of historical

	ID	Description	Example
		be notified of potential authorized uses of <resource>. [see C1] • The system shall allow the owner of <resource> to be notified when the <resource> is <action> by <subject>. [see I2, AY1] • The system shall have the ability to get consent from the owner of <resource> before accessing <resource> for authorized use. [see C1, AY1] • The system shall allow access to <resource> for authorized use without prior consent only under exceptional circumstances as defined by applicable privacy policy. [see I2, AY1]	patient data. • The system shall allow the owner of historical patient data to be notified when the historical patient data is accessed by nurses. • The system shall have the ability to get consent from the owner of historical patient data before accessing historical patient data for authorized use. • The system shall allow access to historical patient data for authorized use without prior consent only under exceptional circumstances as defined by applicable privacy policy.